

ملخص الأمن السيبراني (Cyber Security) – الدروس 1-6



: أحمد الفودعي

1) مفهوم الأمن السيبراني

الأمن السيبراني (Cybersecurity)

التعريف:

هو حماية الأنظمة الرقمية مثل:

- الحواسيب
- الشبكات
- الخوادم
- البرامج
- البيانات

من الهجمات الإلكترونية التي تهدف إلى:

- سرقة البيانات
- تعديل البيانات
- تدمير البيانات
- تعطيل الأنظمة

أمن المعلومات – Information Security (InfoSec)

التعريف:

حماية المعلومات من:

- الوصول غير المصرح
- التعديل
- التدمير

• التسريب

الفرق المهم للاختبار

المصطلح	المعنى
Cybersecurity	حماية الأنظمة والشبكات
Information Security	حماية المعلومات نفسها

2) CIA Triad (مثلث أمن المعلومات)

أحد أهم المفاهيم في الأمن السيبراني.

مثلث أمن المعلومات – CIA Triad

الاختصار	المصطلح	الترجمة
C	Confidentiality	السرية
I	Integrity	سلامة البيانات
A	Availability	التوافر

Confidentiality – السرية

المعنى:

السماح بالوصول إلى البيانات للأشخاص المصرح لهم فقط.

طرق تحقيقها:

- التشفير – Encryption
- التحكم في الوصول – Access Control
- المصادقة متعددة العوامل – MFA

مثال:

عدم قدرة الطلاب على رؤية درجات بعضهم.

Integrity – سلامة البيانات

المعنى:

ضمان أن البيانات لم يتم تغييرها أو تعديلها بدون إذن.

طرق الحفاظ عليها:

- Hash Functions
- Validation
- Checksums

مثال:

عدم قدرة الطالب على تغيير درجته.

التوافر – Availability

المعنى:

أن تكون البيانات أو الأنظمة متاحة عند الحاجة للمستخدم المصرح له.

طرق تحقيقها:

- Backup – النسخ الاحتياطي
- Redundancy – التكرار
- Disaster Recovery – استعادة الكوارث

مثال:

أن يعمل موقع الجامعة دائماً.

3) AAA Framework (إطار AAA)

AAA Framework – إطار AAA

الاختصار	المصطلح	الترجمة
A	Authentication	التحقق من الهوية
A	Authorization	الصلاحيات
A	Accounting	تسجيل النشاط

التحقق من الهوية – Authentication

التعريف:

عملية التأكد من هوية المستخدم.

أمثلة:

- كلمة المرور

- بصمة الإصبع
- بصمة الوجه

التفويض / الصلاحيات – Authorization

التعريف:

تحديد ما الذي يسمح للمستخدم بفعله بعد تسجيل الدخول.

مثال (ما يمكن للمستخدم فعله):

- قراءة البيانات
- تعديل البيانات
- حذف البيانات

تسجيل النشاط – Accounting

التعريف:

تسجيل جميع الأنشطة التي يقوم بها المستخدم في النظام.

يسمى أيضاً:

- Logging

عوامل المصادقة (Authentication Factors)

ثلاثة أنواع مهمة:

النوع	الترجمة	مثال
Something you know	شيء تعرفه	كلمة المرور
Something you have	شيء تملكه	الهاتف
Something you are	شيء تمثله	بصمة الإصبع

4) الأصول في الأمن السيبراني (Assets)

الأصل – Asset

التعريف:

أي شيء له قيمة ويجب حمايته.

أنواع الأصول

النوع	الترجمة
People	الأشخاص
Property	الممتلكات
Information	المعلومات

(5) التهديدات والثغرات

تهديد — Threat

التعريف:

أي شيء قد يسبب ضرر للنظام.

أمثلة:

- فيروس
- هاكلر
- كارثة طبيعية

منفذ التهديد — Threat Actor

التعريف:

الشخص أو الجهة التي تنفذ الهجوم.

مثال:

- Hacker
- Cyber Criminal

ثغرة أمنية — Vulnerability

التعريف:

نقطة ضعف في النظام يمكن للمهاجم استغلالها.

أنواع الثغرات

النوع	المعنى
Design	خطأ في التصميم

النوع	المعنى
Implementation	خطأ في البرمجة
Configuration	إعدادات خاطئة

مثال مهم:

عدم تغيير كلمة المرور الافتراضية.

اختبار الاختراق – Penetration Testing (Pen Test)

التعريف:

اختبار يتم فيه محاكاة هجوم إلكتروني لاكتشاف الثغرات.

(6) الهجمات الإلكترونية

هجوم سبيري – Cyber Attack

التعريف:

محاولة غير قانونية للوصول إلى نظام أو شبكة بهدف:

- سرقة البيانات
- تعطيل الخدمة
- تعديل المعلومات

الدرس الخامس: أنواع الهجمات

هذا الدرس مهم جداً في الاختبار.

هجوم حجب الخدمة – DoS (Denial of Service)

التعريف:

هجوم يهدف إلى تعطيل موقع أو خدمة حتى لا يستطيع المستخدمون الوصول إليها.

هجوم حجب – DDoS (Distributed Denial of Service) الخدمة الموزع

التعريف:

هجوم DoS يتم من عدة أجهزة في نفس الوقت لإغراق الخادم بالطلبات.

برنامج آلي — Bot

التعريف:

برنامج يقوم بتنفيذ مهام تلقائية.

قد يكون:

- مفيد
- خبيث

شبكة البوتات — Botnet

التعريف:

مجموعة من الأجهزة المصابة ببرامج خبيثة ويتحكم بها مهاجم واحد.

جهاز مخترق — Zombie

التعريف:

جهاز مصاب يستخدمه المهاجم داخل شبكة Botnet لتنفيذ الهجمات.

العلاقة بينهم

- يصيب الجهاز Bot →
- عدة أجهزة Botnet →
- الجهاز المصاب Zombie →

DDoS أداة — LOIC (Low Orbit Ion Cannon)

التعريف:

أداة تستخدم لتنفيذ هجمات DDoS.



معلومة مهمة للاختبار: LOIC لا تقوم بإخفاء عنوان IP للمهاجم.

الدرس السادس: هجمات تدمير البيانات

تدمير البيانات – Data Destruction

التعريف:

تدمير البيانات بحيث لا يمكن استرجاعها نهائياً.

هجوم المسح الكامل – Wiper Attack

التعريف:

هجوم يقوم بمسح القرص الصلب بالكامل وتدمير البيانات.

حذف البيانات – Data Deletion

التعريف:

إزالة البيانات من النظام ولكن يمكن استرجاعها أحياناً.

هجوم التلاعب بالبيانات – Tampering Attack

التعريف:

تغيير البيانات أو تعديلها بدون إذن.

أنواع Tampering

- Network Tampering: تغيير البيانات أثناء انتقالها في الشبكة.
- Physical Tampering: تغيير البيانات داخل الجهاز أو النظام.

هجوم انتحال الهوية – Impersonation Attack

التعريف:

المهاجم يتظاهر بأنه شخص موثوق لخداع الضحية.

أنواع Impersonation

التصيد الاحتمالي – Phishing

رسائل أو مواقع مزيفة لسرقة المعلومات.

التصيد الموجه – Spear Phishing

هجوم تصيد يستهدف شخصاً معيناً.

التصيد عبر الرسائل النصية – Smishing

Phishing عبر SMS.

Pharming – إعادة التوجيه إلى موقع مزيف

تحويل المستخدم إلى موقع مزيف حتى لو كتب العنوان الصحيح.

اعتراض البيانات – Interception Attacks

التعريف:

هجوم يتم فيه التقاط البيانات أثناء انتقالها.

هجوم الرجل في الوسط – MITM (Man In The Middle)

التعريف:

المهاجم يقف بين المرسل والمستقبل ويقوم:

- بالتجسس
- بتعديل البيانات

أدوات الاختبار

أداة اختبار الاختراق – Burp Suite

تستخدم في:

- تحليل طلبات المواقع
- اكتشاف الثغرات
- اختبار أمان التطبيقات

أهم الاختصارات التي يجب حفظها

الاختصار	المصطلح	الترجمة
CIA	Confidentiality Integrity Availability	مثلث أمن المعلومات
AAA	Authentication Authorization Accounting	إطار AAA
DoS	Denial of Service	حجب الخدمة

الترجمة	المصطلح	الاختصار
حجب الخدمة الموزع	Distributed Denial of Service	DDoS
الرجل في الوسط	Man In The Middle	MITM
المصادقة متعددة العوامل	Multi Factor Authentication	MFA
التحكم بالوصول حسب الدور	Role Based Access Control	RBAC
DDoS أداة هجوم	Low Orbit Ion Cannon	LOIC

أشياء غالباً تأتي في الاختبار

اختيار من متعدد

- CIA Triad
- AAA Framework

• الفرق بين DoS و DDoS

- Bot / Botnet / Zombie
- Phishing vs Spear Phishing
- MITM Attack
- Data Destruction

صح أو خطأ

- ✓ تتكون من ثلاث عناصر CIA
- ✓ شبكة من الأجهزة المصابة Botnet
- ✓ يعني تعطيل الخدمة DoS
- ✓ يحول المستخدم إلى موقع مزيف Pharming
- ✗ IP يخفي عنوان LOIC
- ✗ يعني تدمير البيانات نهائياً Data deletion